

Enum4linux — Study Guide

Enum4linux is a tool specifically built for enumerating information from Windows and Samba (SMB) systems — picking up right where NSE's `smb-*` scripts left off. Where NSE gives you quick, individual checks, Enum4linux packages the classic Windows/SMB enumeration workflow (built on the older Windows `enum.exe` tool and Samba's `net` / `rpcclient` / `smbclient` utilities) into a single, purpose-built command. It's a cornerstone tool in both traditional Windows pentesting and modern Active Directory recon.

1. What Enum4linux Actually Does

SMB (Server Message Block, port 445, historically also 139) is Windows' file-sharing/RPC protocol — and it's chatty by design. A misconfigured or under-hardened SMB service will happily hand out usernames, group memberships, password policy details, share names, and OS version info to anyone who asks, often without authentication at all (**null sessions**). Enum4linux automates asking all of these questions in one pass.

2. Two Versions Worth Knowing

Version	Notes
enum4linux (original, Perl)	The classic version, pre-installed on Kali for years
enum4linux-ng (Python rewrite)	Actively maintained, structured/JSON output, more reliable against modern Samba/Windows versions

`enum4linux-ng` is generally the better default choice today since the original hasn't been actively maintained and can misbehave against newer Windows Server versions — but both share nearly identical logic and flags, so learning one transfers directly to the other.

```
# Original
enum4linux -a target

# Next-gen (Python)
enum4linux-ng -A target
```

3. Basic Usage

```
enum4linux target
enum4linux -a target          # "all" - run every enumeration check (most common usage)
```

Key Flags

Flag	What It Checks
-U	Users via RID cycling
-M	Machine list
-S	Shares
-P	Password policy
-G	Groups
-d	Detailed output (verbose)
-u	Specify a username (for authenticated enumeration)
-p	Specify a password
-a	All of the above, in one run

```
# Authenticated enumeration (often reveals far more than a null session)
enum4linux -a -u "username" -p "password" target
```

4. What a Full **a** Run Actually Pulls

Running `enum4linux -a target` walks through this checklist automatically:

a) NetBIOS name/workgroup info

Reveals hostname, domain/workgroup name, and NetBIOS-level device role.

b) Null session check

Tests if an unauthenticated ("null") SMB session is permitted — a major finding on its own, since a successful null session usually unlocks everything else below without needing any credentials at all.

c) OS information

```
OS: Windows Server 2012 R2 Standard 9600
```

d) Users (via RID cycling)

Windows assigns every user/group a sequential **RID (Relative Identifier)** appended to the domain SID. Enum4linux tries incrementing RIDs against a known base SID to enumerate every account — including disabled or "hidden" ones not visible through normal means:

```
S-1-5-21-...-500 Administrator (Local User)
S-1-5-21-...-501 Guest (Local User)
S-1-5-21-...-1000 jsmith (Local User)
```

e) Groups

```
Domain Admins
Backup Operators
```

Domain Admins membership is exactly the kind of finding that turns a low-priv foothold into a clear escalation target in an AD engagement.

f) Shares

ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
Users	Disk	

Flags which shares exist and — critically — whether the current session (even a null one) has read/write access to any of them.

g) Password policy

```
Minimum password length: 7
Password history length: 24
Lockout threshold: None
```

A **lockout threshold of "None"** is a huge finding on its own — it means password spraying/brute-forcing against this environment carries no account lockout risk, directly informing your next attack step.

h) Printer info

Less commonly useful today, but still checked as part of a legacy `enum.exe`-style full sweep.

5. Practical Example — Reading the Output

```
enum4linux -a 192.168.1.10
```

```
[+] Server 192.168.1.10 allows sessions using username '', password ''
[+] Got domain/workgroup name: WORKGROUP
[+] OS info for 192.168.1.10: Windows 6.1
[+] Users on 192.168.1.10:
    index: 0x1 RID: 0x1f4 acb: 0x00000010 Account: administrator
    index: 0x2 RID: 0x3ea acb: 0x00000010 Account: msfadmin
[+] Password Policy:
    Minimum password length: 5
    Lockout threshold: None
```

Reading this: a **null session works**, you now have **two confirmed usernames** (`administrator`, `msfadmin`), and there's **no lockout policy** — meaning you can safely try password spraying these two accounts against common/default passwords without risking an account lockout alert.

6. Enum4linux-ng — What's Different

```
enum4linux-ng -A target                # all checks
enum4linux-ng -A -oJ output target      # JSON output
(scriptable/parseable)
```

`enum4linux-ng` structures its output far more cleanly (JSON/YAML export options), handles modern Samba/Windows edge cases better, and is the version most current writeups/OSCP-style guides recommend defaulting to.

7. Under the Hood — What Enum4linux Is Actually Calling

Worth knowing conceptually, since these are the same tools you can run manually if Enum4linux isn't available or you need a more targeted check:

```

smbclient -L //target -N          # list shares, null sessi
on
rpcclient -U "" target           # open an RPC null sessi
on manually
    > enumdomusers                # inside rpcclient - lis
t domain users
    > querydominfo                # domain info incl. pass
word policy
    > netshareenum                # list shares
smbmap -H target                 # share enumeration + ac
cess levels, cleaner output

```

smbmap in particular is worth knowing alongside Enum4linux — it's often used as a quicker follow-up specifically for checking **what access level** (read/write/no access) you actually have on each discovered share.

8. Feeding Enum4linux Results Into Next Steps

Enum4linux is rarely the end of a workflow — its output directly drives what comes next:

```

Usernames found → feed into password spraying (crackmapexec, hydra) or Kerberoasting
(in AD context)
Shares found    → smbclient to browse/download files, check for stored credentials
No lockout policy → safe to brute-force/spray without locking accounts
Null session works → often means the box is a great low-effort target, prioritize it f
irst

```

```

# Example next step - spray discovered usernames against a
common password
crackmapexec smb target -u users.txt -p 'Password123' --con
tinue-on-success

# Browse an accessible share found via enum4linux
smbclient //target/Users -N

```

9. Where This Fits in an AD/Windows Engagement

```
Nmap (-p445 --script=smb-os-discovery)
  ↓ confirms SMB is open, gets a first OS/version hint
Enum4linux -a
  ↓ null session check, users, groups, shares, password policy
smbclient / smbmap
  ↓ browse accessible shares, look for stored creds/config files
crackmapexec / password spraying
  ↓ using harvested usernames + weak/no lockout policy
Further AD enumeration (BloodHound, PowerView)
  ↓ once you have at least one set of valid credentials
```

This is exactly the methodology that shows up in OSCP-style boxes and real AD engagements — Enum4linux is almost always one of the first tools run the moment port 445 shows up open.

10. Kill Chain / ATT&CK Mapping

Framework	Mapping
Cyber Kill Chain	Reconnaissance (often directly enables Weaponization/Delivery via harvested creds)
MITRE ATT&CK	T1087 (Account Discovery), T1069 (Permission Groups Discovery), T1135 (Network Share Discovery), T1201 (Password Policy Discovery)

Notice this single tool touches **four separate ATT&CK techniques** in one run — a good illustration of why Enum4linux remains a go-to first move rather than something replaced entirely by more modern tooling.

11. Defensive Angle (SOC Relevance)

- **Disable null sessions** — the single biggest mitigation; modern Windows disables these by default, but legacy systems/misconfigurations still allow them
- **Restrict anonymous enumeration** via Group Policy: `Network access: Do not allow anonymous enumeration of SAM accounts and shares`
- **Enable account lockout policies** — directly defeats the password spraying that Enum4linux findings usually enable
- **Monitor for RID cycling patterns** — a burst of sequential RID lookup requests against a DC is a strong signal of active enumeration, worth a SIEM detection rule

- **Restrict share permissions** to least privilege — don't rely on obscurity, since Enum4linux will find the shares regardless

12. Legal & Ethical Notes

Enum4linux is an **active** technique — unlike the OSINT tools from earlier guides, it directly connects to and queries the target's SMB service, which is logged and can trigger IDS/IPS alerts. This firmly requires the same authorization principle covered throughout your Nmap/NSE/Netcat study: only run this against systems you own or have explicit written permission to test.

Quick Reference Cheat Sheet

```
enum4linux -a target # classic, all checks
enum4linux-ng -A target # modern rewrite, all checks
enum4linux -a -u "user" -p "pass" target # authenticated enumeration

# Manual equivalents
smbclient -L //target -N # list shares, null session
rpcclient -U "" target # manual RPC null session
smbmap -H target # shares + access level, cleaner output

# Follow-up
crackmapexec smb target -u users.txt -p 'pass' # spray harvested usernames
smbclient //target/ShareName -N # browse an accessible share
```